

■■ PENETRATION TEST REPORT

Critical System Compromise — Supplemental Findings

dashboard.yosicare.com

Security ID	YOSI-SEC-2026-001-S	Date	March 28, 2026
Target	dashboard.yosicare.com	Severity	CRITICAL (9.8 / 10)
Report Type	Supplemental	Status	■ UNPATCHED — ACTIVE RISK

1. EXECUTIVE SUMMARY

A high-priority security assessment of **dashboard.yosicare.com** has uncovered a catastrophic **Path Traversal vulnerability (CVE-2021-39433)**. This flaw allows unauthenticated attackers to bypass filesystem restrictions and read sensitive system and application files.

Critical Impact: The assessment successfully extracted AWS IAM Credentials, Azure AD Secrets, and PHP source code. Access to these keys grants an attacker full control over the application's cloud storage (S3), potentially exposing thousands of Patient Health Information (PHI) records.

Post-exploitation reconnaissance revealed a highly complex internal architecture, exposing production secrets, containerization details, and lateral movement pathways not identified in initial automated scans.

■ **CRITICAL**

CVSS: 9.8 | CWE-22 | CVE-2021-39433

Auth Required: NONE

2. TECHNICAL FINDINGS & RECONNAISSANCE

2.1 Path Traversal — CWE-22

The `/download/index.php` endpoint fails to sanitize the `file` parameter, allowing arbitrary file disclosure via directory traversal sequences.

2.2 Infrastructure & Network Topology

Post-exploitation enumeration revealed the following internal architecture:

COMPONENT	VALUE	SIGNIFICANCE
Environment	Docker (overlay2 driver)	Containerised deployment
Container ID	2a30*****994a	Fingerprinted host
Internal Node IP	172.26.11.168	App container address
Docker Bridge IP	172.17.0.4	Bridge network confirmed
NFS Mount	172.26.42.127:/logs	Remote logging infrastructure

2.3 Secrets Management & Lateral Pathways

HashiCorp Vault Endpoint: 172.10.102.54:8200

The application container maintains an active TCP connection to this internal Vault instance, indicating dynamic secret retrieval at runtime. This endpoint represents a critical pivot point for total infrastructure compromise — a successful attacker could request backend database credentials, SSH private keys, and additional service tokens directly from Vault.

3. EXPOSED SECRETS & CLOUD ASSETS

■ All credential values are redacted in this report. Full values were captured during assessment. Client must rotate all secrets immediately.

3.1 Cloud Storage Credentials

SERVICE	KEY NAME	VALUE (REDACTED)	STATUS
AWS S3	S3_BUCKET_KEY	AKIA****.***JSV2	■ Active
AWS S3	S3_BUCKET_SECRET	T9GV****.***NEqT	■ Active

Compromised S3 Buckets (us-west-2):

BUCKET	CONTENTS	DATA TYPE
s3dev-signature.yosicare.com	Patient Signatures	PHI
s3dev-pdf.yosicare.com	Clinical Records	PHI / HIPAA
s3dev-csv.yosicare.com	PII Exports	PII

3.2 Identity & Authentication Tokens

SERVICE	KEY NAME	VALUE (REDACTED)	SCOPE / IMPACT
Azure AD	CLIENT_ID	13c5****.***a528	Production Tenant
Azure AD	CLIENT_SECRET	oZr8****.***Ibp3	Tenant Impersonation

OAuth2 Integration Risk — Undocumented Finding

Target API: api.platform.athenahealth.com
Scope: fhirUser / offline_access / openid / profile

The exposed Azure AD CLIENT_SECRET, combined with the fhirUser FHIR scope, enables an attacker to systematically exfiltrate Patient Health Information (PHI) directly from the AthenaHealth API via Authorization Code spoofing — without any user interaction.

4. STRATEGIC REMEDIATION (UPDATED)

■ PHASE 1 — IMMEDIATE CONTAINMENT (0–4 Hours)

1 Deactivate AWS Keys

Immediately revoke the AKIA... IAM user in the AWS Console. Do not disable — delete and recreate with least-privilege scoping.

2 Rotate Azure Secrets

Generate a new CLIENT_SECRET in Azure AD Portal and update all environment configs referencing the old value.

3 Emergency PHP Patch

Add input sanitisation to download/index.php to block traversal immediately:

```
$file = basename($_GET['file']); // emergency only – not sufficient long-term
```

■ PHASE 2 — SYSTEM HARDENING (Next 7 Days)

1 Migrate to IAM Roles

Eliminate hardcoded keys in config.php. Use EC2 IAM Roles for temporary, auto-rotating S3 access.

2 Secrets Management

Move all API keys and secrets to AWS Secrets Manager or HashiCorp Vault. Never store plaintext credentials in source files.

3 Filesystem Permissions

Ensure the apache user has no read access outside the web root (/var/www/html). Review all DAC controls.

4 Isolate Vault [NEW]

Restrict the HashiCorp Vault instance (172.10.102.54:8200) from direct unauthenticated container access. Enforce strict JWT/AppRole policies.

5 Segment NFS [NEW]

Segment the NFS logging server (172.26.42.127) from the public-facing application bridge to prevent lateral poisoning attacks.

5. CONCLUSION

The security posture of **dashboard.yosicare.com** is currently compromised. The ability to retrieve live production credentials via a single unauthenticated HTTP request represents a critical failure of secure coding practice.

Exposed S3 buckets contain patient signatures, clinical records, and PII exports protected under HIPAA. The additional discovery of an internal Vault endpoint and NFS logging server significantly expands the blast radius. **Immediate action is required to prevent a HIPAA-reportable data breach.**

This report was produced by an independent third-party security assessor. All credential values have been redacted prior to delivery. The client is solely responsible for all remediation actions and for determining HIPAA breach notification obligations under 45 CFR §164.400.